

**Министерство науки и высшего образования Российской Федерации
ФЕДЕРАЛЬНОЕ ГОСУДАРСТВЕННОЕ АВТОНОМНОЕ ОБРАЗОВАТЕЛЬНОЕ
УЧРЕЖДЕНИЕ ВЫСШЕГО ОБРАЗОВАНИЯ
НАЦИОНАЛЬНЫЙ ИССЛЕДОВАТЕЛЬСКИЙ УНИВЕРСИТЕТ ИТМО**

Факультет безопасности информационных технологий

Дисциплина:

«Организационно-правовое обеспечение информационной безопасности»

ОТЧЕТ ПО ЛАБОРАТОРНОЙ РАБОТЕ №3

«Организационная защита информации»

Выполнили:

Жук Анастасия Валерьевна,
студент группы N3348

(подпись)

Проверил:

Евглевская Наталья Валерьевна,
к.т.н., доцент ФБИТ

(дата)

(отметка о выполнении)

(подпись)

Санкт-Петербург

2026 г.

СОДЕРЖАНИЕ

Введение	3
Ход работы	4
1 Виды организационной защиты информации	6
1.1 Административные меры: корпоративные ОРД	6
1.2 Управление персоналом.....	7
2 Классификация организационной защиты информации	8
2.1 Организация режима и охраны	8
2.2 Организация работы с сотрудниками.....	8
2.3 Организация работы с документами	9
2.4 Организация использования технических средств	9
2.5 Организация работы по анализу внутренних и внешних угроз.....	9
3 Взаимосвязь организационной защиты с другими видами защиты информации.....	11
Заключение.....	12
Список использованных источников.....	13

ВВЕДЕНИЕ

Цель работы – изучить сущность, содержание и практическое значение организационных мер защиты информации, а также освоить принципы их применения для минимизации рисков, связанных с человеческим фактором в системе обеспечения информационной безопасности организации.

Для достижения поставленной цели необходимо решить следующие задачи:

- раскрыть понятие и значение организационной защиты в системе информационной безопасности;
- изучить административные меры и методы управления персоналом;
- систематизировать классификацию организационных мер по направлениям деятельности;
- проанализировать взаимосвязь организационных мер с правовыми и техническими видами защиты.

ХОД РАБОТЫ

Организационные меры защиты информации – это деятельность по регламентации действий сотрудников организации, направленная на обеспечение информационной безопасности. Необходимо подчеркнуть, что регламентации подлежит не только деятельность, непосредственно связанная с созданием или использованием информационных ресурсов, но и действия, так или иначе затрагивающие поддерживающую инфраструктуру либо обслуживающий персонал [3].

Более формальное определение звучит следующим образом: **организационная защита информации** – это регламентация производственной деятельности и взаимоотношений исполнителей на нормативно-правовой основе таким образом, что несанкционированный доступ к конфиденциальной и секретной информации становится невозможным или существенно затрудняется за счет проведения организационных мероприятий [3].

Человеческий фактор является главной уязвимостью в работе с информацией. Человек может проявить невнимательность, халатность или действовать против интересов компании – например, украсть данные или заразить корпоративную сеть вредоносным программным обеспечением. Статистика подтверждает: более 70–95% успешных кибератак происходят именно из-за организационных просчетов и человеческого фактора, а не из-за технических уязвимостей [1].

Рассмотрим конкретные примеры инцидентов, произошедших вследствие организационных провалов [1]:

- Equifax (2017): утечка данных 147 миллионов человек произошла из-за того, что не была внедрена процедура своевременного обновления программного обеспечения; патч не был установлен вовремя, что привело к штрафу в размере 575 миллионов долларов и серьезному репутационному ущербу;
- Target (2013): кража данных 40 миллионов кредитных карт стала возможной из-за отсутствия сегментации сети и игнорирования предупреждений системы безопасности;
- Uber (2016): утечка данных 57 миллионов пользователей произошла вследствие отсутствия политики раскрытия инцидентов: руководство скрыло факт взлома, что повлекло штраф в 148 миллионов долларов и возбуждение уголовных дел;
- Snapchat (2014): утечка данных 4,6 миллиона пользователей произошла из-за отсутствия обучения персонала по кибергигиене: сотрудник поверил фишинговому письму;

– Morrisons (2014): инсайдер скопировал данные 100 000 сотрудников из-за отсутствия разделения обязанностей и контроля за привилегированными пользователями.

Данные примеры наглядно демонстрируют: даже самые совершенные технические средства бесполезны без четких организационных процедур, обучения персонала и контроля исполнения.

1 ВИДЫ ОРГАНИЗАЦИОННОЙ ЗАЩИТЫ ИНФОРМАЦИИ

Организационная защита реализуется через два взаимосвязанных направления [4]: административные меры (корпоративные ОРД) и управление персоналом.

1.1 Административные меры: корпоративные ОРД

Организационно-распорядительная документация (ОРД) – это совокупность внутренних документов организации, регламентирующих процессы защиты информации [2].

Административные меры представляют собой формальные, зафиксированные и неизменные для рядовых сотрудников правила. Это документы, которые регламентируют работу и поведение персонала. Изменять их могут только руководители организации.

Структура корпоративных ОРД в сфере информационной безопасности включает следующие группы документов [2]: стратегические документы, положения и регламенты, инструкции и методики, кадровые документы, учетные формы. К **стратегическим документам** относятся политика информационной безопасности, политика обработки персональных данных и концепция развития системы защиты информации. К **положениям и регламентам** – положение об обработке и защите персональных данных, регламент управления доступом к информационным ресурсам, регламент реагирования на инциденты информационной безопасности и порядок резервного копирования и восстановления данных. К **инструкциям и методикам** – инструкция пользователя по безопасной работе, инструкция администратора по настройке средств защиты информации, методика оценки угроз безопасности информации и памятки по работе с конфиденциальными данными. К **кадровым документам** – должностные инструкции с требованиями по информационной безопасности, обязательства о неразглашении (NDA) и журналы инструктажей и обучения персонала. К **учетным формам** – журналы учета носителей информации, акты уничтожения документов и протоколы проверок и аудитов.

Основой организационных мер защиты является политика информационной безопасности организации [3]. **Политика информационной безопасности** – это документальное оформление правил поведения, процедур, практических приемов или руководящих принципов в отношении защиты данных, которыми руководствуется организация в своей деятельности.

1.2 Управление персоналом

Если административные меры представляют собой формальные документы, то управление персоналом – это работа с людьми непосредственно: проведение конференций, тренингов, инструктажей, погружение сотрудников в вопросы информационной безопасности. Как отмечают специалисты, «персонал – это всегда самое слабое звено в системе безопасности, и с ним нужно постоянно работать» [4].

Управление персоналом включает такие мероприятия по работе с персоналом, как подбор и проверка, обучение и информирование, мотивация и контроль, а также работа с увольняющимися сотрудниками. **Подбор и проверка персонала** заключается в квалифицированной оценке соискателей при приеме на работу, проверке идентичности личности, заявленной квалификации, точности биографических фактов, а также в ознакомлении с рекомендациями с предыдущих мест работы, если таковые имеются. **Обучение и информирование** производится путем регулярного обучения персонала в области информационной безопасности, своевременного информирования об актуальных угрозах, периодической проверки уровня компетентности сотрудников. **Мотивация и контроль** организуются с помощью взятия с персонала письменного обязательства о соблюдении конфиденциальности, материального поощрения сотрудников, соблюдающих регламент работы с конфиденциальной информацией, а также формирования приверженности единым правилам корпоративной этики. **Работа с увольняющимися сотрудниками** заключается в отзыве прав доступа к информационным ресурсам, возврате носителей информации и проведении выходного интервью [3].

2 КЛАССИФИКАЦИЯ ОРГАНИЗАЦИОННОЙ ЗАЩИТЫ ИНФОРМАЦИИ

Организационная защита информации включает пять основных направлений, каждое из которых решает специфические задачи по обеспечению безопасности информации в организации.

2.1 Организация режима и охраны

Данное направление включает комплекс мер по созданию и поддержанию пропускного режима на территории организации, охране помещений и контролю доступа к информационным ресурсам. Согласно учебному пособию Д.В. Шибеева, организация режима и охраны предполагает:

- установление правил доступа на территорию организации и в помещения;
- организацию контрольно-пропускных пунктов;
- оборудование помещений техническими средствами охраны (сигнализация, видеонаблюдение);
- определение перечня помещений с особыми условиями доступа;
- организацию физической охраны объектов информатизации [4].

2.2 Организация работы с сотрудниками

Это направление занимается минимизацией рисков, связанных с человеческим фактором. Как отмечается в учебном пособии А.Н. Прокопенко, работа с персоналом включает:

- подбор и расстановку кадров с учетом требований информационной безопасности;
- проведение проверок при приеме на работу;
- обучение и инструктирование сотрудников по вопросам защиты информации;
- ознакомление персонала с локальными нормативными актами под роспись;
- проведение регулярных тренировок по действиям в нештатных ситуациях;
- мотивацию сотрудников к соблюдению требований информационной безопасности;
- контроль за действиями персонала при работе с конфиденциальной информацией [3].

2.3 Организация работы с документами

Данное направление охватывает весь жизненный цикл документов, содержащих конфиденциальную информацию:

- разработку перечня сведений, подлежащих защите;
- установление правил документирования информации;
- организацию учета, хранения и использования документов;
- определение порядка передачи документов между подразделениями;
- установление правил работы с документами вне офиса;
- организацию уничтожения документов с истекшими сроками хранения;
- ведение журналов учета документов [4].

2.4 Организация использования технических средств

Это направление включает регламентацию работы с техническими средствами обработки информации:

- установление правил эксплуатации компьютерной техники;
- определение порядка подключения внешних носителей информации;
- регламентацию доступа к сети Интернет и электронной почте;
- установление правил использования мобильных устройств;
- организацию резервного копирования информации;
- контроль за установкой программного обеспечения;
- обеспечение антивирусной защиты [3].

2.5 Организация работы по анализу внутренних и внешних угроз

Данное направление обеспечивает своевременное выявление и оценку угроз информационной безопасности:

- проведение регулярного мониторинга угроз;
- анализ инцидентов информационной безопасности;
- оценку уязвимостей информационных систем;
- разработку мер по нейтрализации выявленных угроз;
- ведение базы данных угроз и инцидентов;
- периодический пересмотр и актуализацию модели угроз [4].

Все пять направлений организационной защиты тесно взаимосвязаны и должны реализовываться комплексно. Как отмечают специалисты, именно организационные меры составляют 50–60% в структуре большинства систем защиты информации, что подчеркивает их критическую важность для обеспечения информационной безопасности организации [3].

3 ВЗАИМОСВЯЗЬ ОРГАНИЗАЦИОННОЙ ЗАЩИТЫ С ДРУГИМИ ВИДАМИ ЗАЩИТЫ ИНФОРМАЦИИ

Организационная защита информации не существует изолированно. Она тесно связана с правовой и инженерно-технической защитой. Правовая защита (ФЗ, указы, приказы) требует для собственного обеспечения организационной защиты (ОРД, обучение, контроль), которая в свою очередь задает требования к инженерно-технической защите (фаерволам, шифрованию, средствам защиты информации). Но также важно отметить, что связь организационной и инженерно-технической защит является двусторонней: технические средства также могут выявлять недостатки в организационных мерах (например, логи показывают, что сотрудник нарушает инструкцию), что приводит к корректировке ОРД.

Пример реализации на практике. Федеральный закон № 152-ФЗ «О персональных данных» (правовая защита) требует обеспечения безопасности персональных данных, политика информационной безопасности и инструкция по работе с персональными данными (ОРД, организационная защита) регламентируют, как именно сотрудники должны обрабатывать такие данные, настройка прав доступа в СУБД и шифрование данных (инженерно-техническая защита) реализует технические требования, заданные организационными документами.

Таким образом, организационная защита является связующим звеном между правовой базой и технической реализацией. Без ОРД даже самые совершенные технические средства могут использоваться неправильно.

ЗАКЛЮЧЕНИЕ

Организационная защита информации выступает в роли управленческой основы системы информационной безопасности, охватывающей регламентацию бизнес-процессов и нейтрализацию рисков человеческого фактора, тогда как правовые и технические меры – это ее нормативная и инструментальная реализация, сфокусированная на закреплении требований и их аппаратно-программном воплощении.

СПИСОК ИСПОЛЬЗОВАННЫХ ИСТОЧНИКОВ

1. 10 Security Breaches Caused by Employees [Электронный ресурс]. – Режим до: <https://www.techclass.com/resources/learning-and-development-articles/10-security-breaches-caused-by-employees> (дата обращения: 20.05.2026)
2. Евглевская, Н. В. Организационное и правовое обеспечение информационной безопасности [Электронный ресурс] : презентация / Н. В. Евглевская. – 97 слайда.
3. Основы кибербезопасности в деятельности сотрудников правоохранительных органов : учебное пособие / А. Н. Прокопенко [и др.]. – Белгород : Белгородский юридический институт МВД России имени И. Д. Путилина, 2023. – 153 с. – ISBN 978-5-91776-485-6.
4. Шибает, Д. В. Организационно-правовое обеспечение информационной безопасности : учебное пособие / Д. В. Шибает ; Северо-Западный институт (филиал) Университета имени О. Е. Кутафина (МГЮА). – Вологда : Северо-Западный ин-т (филиал) Ун-та им. О. Е. Кутафина (МГЮА), 2024. – 178 с. – Текст: электронный. – ISBN 978-5-6050185-1-3.